

ДЕПАРТАМЕНТ ОБРАЗОВАНИЯ ТОМСКОЙ ОБЛАСТИ

ОБЛАСТНОЕ ГОСУДАРСТВЕННОЕ БЮДЖЕТНОЕ
ОБРАЗОВАТЕЛЬНОЕ УЧРЕЖДЕНИЕ
«ТОМСКИЙ ТЕХНИКУМ ИНФОРМАЦИОННЫХ ТЕХНОЛОГИЙ»

Специальность 09.02.07 и программирование
Специальность 09.02.07 Информационные системы и программирование

Практическая работа №1

Студент гр. 622
20 октября 2025 г.

_____ В. В. Силаев

Преподаватель
20 октября 2025 г.

_____ Ю. С. Чернова

Томск 2025

Ситуация:

Ваша компания разрабатывает новое программное обеспечение. Для обеспечения качества ,безопасности и соответствия требованиям необходимо внедрить новые стандарты.

1) Название компании: «Лаборатория Касперского» (Kaspersky Lab)

Компания занимается разработкой решений в области защиты от киберугроз для домашних пользователей, малого и крупного бизнеса, а также государственных учреждений.

Программное обеспечение называется Kaspersky Proactive Shield.

Kaspersky Proactive Shield - это новое поколение комплексной защиты конечных точек, выходящее за рамки традиционного антивируса. Продукт сочетает в себе предиктивные технологии на основе искусственного интеллекта и машинного обучения с классическими сигнатурными методами для опережающего реагирования на угрозы.

Ключевые функции и особенности:

Предиктивный анализ угроз: Использует ИИ-модели для анализа поведения программ и процессов в реальном времени, блокируя подозрительную активность до того, как она нанесет вред.

Эмуляция песочницы: Подозрительные файлы автоматически запускаются в изолированной виртуальной среде для анализа их поведения без риска для системы.

Полный контроль приложений: Система контроля приложений с белыми и черными списками, предотвращающая запуск нежелательного и вредоносного ПО.

Защита от ransomware (анти-шифровальщик): Специализированный модуль, отслеживающий подозрительную активность, характерную для шифровальщиков, и автоматически откатывающий изменения.

Управление уязвимостями: Сканирует установленное программное обеспечение и операционную систему на наличие известных уязвимостей и помогает их устранить.

Конфиденциальность данных: Защита веб-камеры, блокировка кейлоггеров и шифрование данных в хранилище.

И т.д. менее крупные особенности ПО.

2) Цели и задачи при внедрении стандартов в процесс разработки.

Цели:

Максимальная эффективность защиты: Обеспечение высочайшего уровня обнаружения и нейтрализации угроз.

Стабильность и производительность: Гарантия того, что антивирусное ПО не замедляет работу защищаемых систем и не конфликтует с другим легитимным программным обеспечением.

Безопасность самого ПО: Защита ядра и компонентов антивируса от взлома и манипуляций со стороны злоумышленников.

Соответствие глобальным требованиям кибербезопасности: Обеспечение возможности сертификации продукта по международным стандартам.

Прозрачность и доверие: Демонстрация открытости и надежности процессов разработки.

Задачи:

Внедрить стандартизированный жизненный цикл разработки ПО, включая обязательные этапы безопасного аудита кода.

Создать и поддерживать актуальную базу знаний о современных угрозах.

Внедрить автоматизированное тестирование на проникновение как самого ПО, так и его инфраструктуры.

Разработать и внедрить политику безопасного кодирования.

Наладить процесс независимой верификации эффективности защиты в специализированных лабораториях.

Обеспечить соответствие требованиям по защите персональных данных в разных юрисдикциях.

3) Принципы внедрения стандартов в области ИТ и их влияние на эффективность

Принцип «Безопасность по дизайну»: Вопросы безопасности должны быть заложены в архитектуру продукта с самого начала, а не добавляться на последних этапах.

Влияние: Кардинально снижает стоимость исправления уязвимостей. Повышает общую устойчивость продукта к атакам.

Принцип минимальных привилегий: Каждый компонент системы должен работать с минимальным набором привилегий, необходимым для выполнения его функций.

Влияние: Ограничивает потенциальный ущерб в случае компрометации одного из модулей антивируса.

Принцип непрерывного мониторинга и улучшения: Процессы защиты и разработки должны постоянно отслеживаться и совершенствоваться на основе новых данных об угрозах.

Влияние: Позволяет продукту и процессам его создания адаптироваться к быстро меняющемуся ландшафту киберугроз.

Принцип проверки: Реализация подхода «Не доверяй, но проверяй» как в логике работы антивируса, так и в процессах разработки.

Влияние: Повышает устойчивость к сложным цепочечным атакам и внутренним угрозам.

Принцип прозрачности и подотчетности: Все процессы, особенно связанные с обработкой данных, должны быть документированы и прозрачны для внутреннего и внешнего аудита.

Влияние: Формирует доверие партнеров и клиентов, что особенно важно в свете повышенного внимания к антивирусному ПО.

4) Нормативные документы и виды применимых стандартов

Необходимо учитывать:

Международные стандарты и сертификации:

ISO/IEC 27001: Основа для построения системы менеджмента информационной безопасности в компании.

ISO/IEC 15408: Сертификация по уровню EAL доказывает надежность продукта.

ISO/IEC 27034: Безопасность приложений - предоставляет руководство по внедрению безопасности в процессы разработки.

Отраслевые стандарты тестирования:

Стандарты независимых тестовых лабораторий: AV-TEST, SE Labs. Требованиям этих организаций продукт должен соответствовать, чтобы показывать высокие результаты в рейтингах.

Национальные стандарты:

Серия ГОСТ Р ИСО/МЭК 27000: Российская версия международных стандартов.

Требования ФСТЭК России: Например, «Профиль защиты средств антивирусной защиты». Сертификация ФСТЭК обязательна для использования продукта в государственных информационных системах и критической информационной инфраструктуре (КИИ).

Федеральный закон № 152-ФЗ «О персональных данных»: Регулирует обработку данных, которые антивирус может затрагивать при сканировании.

GDPR (ЕС): При работе на европейском рынке.

Виды стандартов:

Стандарты процессов ISO 27001: Регламентируют управление безопасностью в компании.

Стандарты оценки продуктов: Определяют, как оценивать безопасность и надежность самого антивируса.

Технические стандарты профилей защиты ФСТЭК: Описывают конкретные технические требования к функциям антивирусного ПО.

5) Организации и специалисты, вовлеченные в процесс внедрения стандартов

Процесс внедрения стандартов для продукта является комплексным и требует участия широкого круга внутренних и внешних стейкхолдеров. Их можно разделить на несколько ключевых групп.

Стратегическое руководство и управление:

Руководство «Лаборатории Касперского» (Топ-менеджмент): Эта группа несет конечную ответственность за успех проекта. Их роль заключается в утверждении стратегии внедрения стандартов, выделении необходимых финансовых и человеческих ресурсов, а также в создании корпоративной культуры, ориентированной на качество и безопасность. Они утверждают политики и несут ответственность перед акционерами и рынком за соответствие продукта заявленным стандартам.

Ключевые технические и экспертные отделы компании:

Главный архитектор продукта и ведущие разработчики: Ответственны за то, чтобы требования стандартов были корректно интегрированы в архитектуру и код продукта. Их задача - реализовать такие принципы, как

«Безопасность по дизайну» и минимальные привилегии, на техническом уровне. Они участвуют в аудитах кода и несут ответственность за устранение выявленных архитектурных недостатков.

Отдел исследований угроз: Выступает в роли внутренних экспертов по кибербезопасности. Их ответственность - обеспечить, чтобы продукт соответствовал не только формальным требованиям стандартов, но и реальным угрозам. Они предоставляют данные для тестирования, валидируют эффективность новых защитных механизмов и участвуют в создании технических требований, основанных на актуальных тактиках и техниках злоумышленников.

Менеджер по качеству и соответствию: Является центральной фигурой, координирующей весь процесс. Его зона ответственности - управление проектом по сертификации, взаимодействие с внешними органами по сертификации, подготовка всей необходимой документации и обеспечение того, чтобы все этапы разработки соответствовали выбранным стандартам.

Специалисты по тестированию и пентесту: Эта группа отвечает за практическую проверку соответствия. Тестировщики (QA) обеспечивают, чтобы все функции продукта работали в соответствии с техническими заданиями, созданными на основе стандартов. Пентестеры несут ответственность за активный поиск уязвимостей в продукте и его инфраструктуре путем моделирования атак, что является критически важной частью стандартов безопасности.

Вспомогательные и обеспечивающие подразделения:

Юридический отдел и Специалист по защите данных: Их роль - обеспечение правового соответствия. Они несут ответственность за анализ законодательных требований, подготовку лицензионных соглашений и

политик конфиденциальности, которые должны быть прозрачными и соответствовать международным нормам.

Отдел разработки и эксплуатации (DevOps): Ответственен за соответствие стандартам процессов сборки, развертывания и мониторинга. Их задача - обеспечить безопасность конвейера CI/CD, гарантировать целостность сборок и защиту ключей шифрования, что является требованием многих стандартов управления безопасностью.

Внешние стейкхолдеры и сертифицирующие органы:

Национальные и международные органы по сертификации: Эти независимые организации несут ответственность за объективную оценку продукта и процессов компании. Их роль заключается в проведении официального аудита, проверке документации и тестов, и, в случае успеха, - в выдаче сертификата соответствия, который является официальным документом, подтверждающим качество и безопасность продукта.

Независимые тестовые лаборатории: Хотя они и не выдают юридические сертификаты, их рейтинги являются де-факто отраслевым стандартом. Их ответственность - проведение сравнительных тестов эффективности защиты. Успешное прохождение этих тестов является практическим доказательством выполнения целей, заложенных в процессе внедрения стандартов, и напрямую влияет на доверие рынка и коммерческий успех продукта.